
**CONCEPTO
ARQUITECTURA EMPRESARIAL
ONBOARDIN TARJETAHABIENTE
CREDIBANCO**

VERSIÓN 1.0

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
25/05/2026	1.0	Versión Inicial	Javier Ricardo Agudelo

TABLA DE CONTENIDO

HISTORIA DE REVISIONES	2
TABLA DE CONTENIDO	3
GUÍA DE USO	4
NECESIDAD.....	5
PREMISAS DEL CONCEPTO	7
LINEAMIENTOS	10
RESTRICCIONES	13
ARQUITECTURA PROPUESTA	16
Diagrama de Arquitectura.....	16
Descripción de componentes	17
Descripción del proceso.....	19
Aplicaciones y/o soluciones afectadas	25
ANEXOS.....	26

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.
- No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".
- No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.
- Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.

NECESIDAD

El presente concepto se enfoca en definir la arquitectura requerida para soportar el proceso de Onboarding de Tarjetahabiente de la plataforma prepago de Credibanco, permitiendo que un tarjetahabiente cuya tarjeta nominada ha sido creada en el sistema pueda activar su cuenta en el Portal Tarjetahabiente, mediante un flujo seguro de pre-registro, verificación de identidad, validación OTP, asignación de contraseña y creación de usuario en el SSO corporativo.

La necesidad surge de habilitar una capacidad centralizada, segura, trazable y auditable que permita a los tarjetahabientes acceder al portal de autoservicio una vez se haya creado una tarjeta prepago nominada asociada a su información personal. Este proceso debe garantizar que únicamente el titular legítimo pueda completar la activación de su cuenta, validando la información registrada previamente por la Entidad y aplicando un segundo factor de verificación mediante OTP enviado al correo electrónico registrado.

El flujo de onboarding debe permitir que, posterior a la creación de una tarjeta nominada, se genere un pre-registro asociado al cliente, se construya una URL única mediante un código UUID, se envíe un correo transaccional al tarjetahabiente y se habilite una experiencia web pública para completar el proceso de activación de cuenta. Esta activación debe incluir la verificación de tipo y número de documento, validación del correo registrado, generación y validación de OTP, asignación de contraseña y creación del usuario en SSO Keycloak Realm CARDHOLDER.

La arquitectura debe contemplar que el onboarding se active principalmente a partir de la creación de una tarjeta nominada, pero también debe soportar disparadores adicionales asociados al cambio de correo electrónico del tarjetahabiente y al reenvío manual del enlace desde el Portal Administrativo. En todos los casos, el proceso debe mantener idempotencia por `client_id`, evitando generar múltiples pre-registros vigentes para un mismo cliente cuando ya exista un registro en estado pendiente y no expirado.

El proceso debe soportar la generación de un código único de pre-registro con vigencia controlada, el envío de una URL de activación al correo registrado, la validación de identidad del tarjetahabiente mediante datos conocidos, y la posterior generación de un OTP de seis dígitos con vigencia limitada. El OTP debe validarse bajo reglas de seguridad, intentos máximos, expiración y bloqueo, evitando su almacenamiento en claro y garantizando trazabilidad de cada intento.

La solución debe permitir que, una vez validada la identidad y confirmado el OTP, el tarjetahabiente pueda asignar una contraseña que cumpla las políticas de seguridad definidas. Posteriormente, se debe crear el usuario en el SSO, registrar la relación con el cliente en la tabla de usuarios de aplicación, actualizar el estado del pre-registro a COMPLETADO y permitir que el tarjetahabiente sea redirigido al Portal Tarjetahabiente para autenticarse con su número de documento y contraseña.

La arquitectura propuesta debe contemplar los componentes necesarios para la ejecución del proceso, incluyendo el `PreRegistration_Portal`, `PreRegistration_API`, `PreRegistration_Service`, `OTP_Service`, `B2B_Mail_Service`, `SMTP Server`, `SSO Keycloak`, `Audit_Service` y la base de datos Oracle donde se administran las tablas de `preregistration`, `otp`, `app_user` y `client`. Estos componentes deben operar de forma desacoplada, segura y trazable, manteniendo separación entre experiencia de usuario, lógica de negocio, generación de OTP, notificación, identidad, persistencia y auditoría.

El alcance del onboarding aplica únicamente para tarjetas nominadas. Las tarjetas innominadas quedan excluidas de este flujo y deberán gestionarse mediante el proceso correspondiente de activación definido para ese tipo de tarjeta. De igual forma, los flujos transaccionales de autorización, activación de PIN y cambio de PIN no hacen parte de este concepto, dado que corresponden a otros diagramas y capacidades del ecosistema prepago.

Desde la perspectiva de seguridad, la solución debe garantizar controles sobre autenticación, validación de identidad, generación y validación de OTP, protección de contraseña, manejo seguro de sesión, control de intentos, rate limiting, CAPTCHA,

trazabilidad, auditoría y registro de eventos sensibles. Adicionalmente, debe evitar la exposición de información sensible en correos, logs, consola del navegador, respuestas técnicas o trazas operativas.

En este sentido, la arquitectura propuesta para Onboarding Tarjetahabiente debe permitir:

- Generar automáticamente un pre-registro al crear una tarjeta nominada.
- Enviar al tarjetahabiente un correo transaccional con un enlace único de activación.
- Validar la identidad del tarjetahabiente mediante tipo de documento, número de documento y correo registrado.
- Generar, enviar y validar un OTP de seis dígitos con vigencia limitada.
- Controlar intentos máximos de verificación de identidad y validación de OTP.
- Bloquear el proceso cuando se superen los intentos permitidos.
- Permitir la asignación de contraseña bajo política de seguridad.
- Crear el usuario en SSO Keycloak Realm CARDHOLDER.
- Registrar el usuario activo en la solución prepago.
- Actualizar el estado del pre-registro a COMPLETADO.
- Redirigir al tarjetahabiente al Portal Tarjetahabiente una vez finalizado el proceso.
- Soportar reenvío de enlace por cambio de correo o gestión desde Portal Administrativo.
- Registrar auditoría funcional, técnica y de seguridad de todo el flujo.
- Mantener trazabilidad completa en audit_log y pci_event_log.
- Excluir tarjetas innominadas y flujos transaccionales de PIN/autorización del alcance de este concepto.

Con esta capacidad, Credibanco busca asegurar que la activación de cuenta del tarjetahabiente se realice de forma controlada, segura, auditable y alineada con el ciclo de vida de tarjetas prepago nominadas, reduciendo riesgos de suplantación, duplicidad de usuarios, pérdida de trazabilidad, exposición de información sensible y errores operativos en el proceso de habilitación del Portal Tarjetahabiente.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta para el proceso de Onboarding de Tarjetahabiente, entendido como el flujo de pre-registro y activación de cuenta en el Portal Tarjetahabiente para clientes con tarjeta prepago nominada.

- El proceso de onboarding aplica únicamente para tarjetas nominadas. Las tarjetas innominadas no hacen parte de este flujo y deberán gestionarse mediante el proceso definido para activación de tarjetas innominadas.
- El onboarding se ejecuta como una capacidad posterior a la creación de una tarjeta prepago nominada, permitiendo que el tarjetahabiente active su cuenta en el Portal Tarjetahabiente mediante verificación de identidad, validación OTP y asignación de contraseña.
- La arquitectura propuesta contempla que el pre-registro sea disparado automáticamente cuando se crea una tarjeta nominada y el tarjetahabiente no cuenta con usuario previamente registrado en la solución.
- El proceso deberá soportar tres disparadores principales: creación de tarjeta nominada, modificación de correo electrónico del tarjetahabiente y operación puntual desde el Portal Administrativo para reenvío manual del enlace de pre-registro.
- El pre-registro deberá ser idempotente por `client_id` y no por `card_id`. Si un mismo tarjetahabiente recibe varias tarjetas, deberá conservarse un único pre-registro vigente asociado al cliente.
- Si ya existe un pre-registro en estado PENDIENTE y con vigencia activa para el mismo cliente, la solución deberá reutilizar el código existente y reenviar el correo, en lugar de generar múltiples códigos activos.
- El código de pre-registro deberá generarse como un identificador único tipo UUID v4, asociado al cliente y con una vigencia máxima de 30 días.
- El enlace de pre-registro deberá ser enviado únicamente al correo electrónico registrado para el tarjetahabiente. El correo electrónico es un dato obligatorio para habilitar el proceso de onboarding.
- La URL de pre-registro deberá contener un código opaco y no deberá exponer datos personales, número de tarjeta, PAN, CVV2, documento, correo ni información sensible del tarjetahabiente.
- El flujo deberá estar soportado por un portal público de pre-registro, identificado como `PreRegistration_Portal`, desde el cual el tarjetahabiente completará las fases de verificación de identidad, OTP y asignación de contraseña.
- El portal de pre-registro deberá consumir exclusivamente los servicios expuestos por `PreRegistration_API`, evitando acceso directo del front-end a la base de datos, SSO, servicios de OTP o servicios de correo.
- La lógica funcional del onboarding deberá estar centralizada en `PreRegistration_Service`, que actuará como componente principal de negocio y orquestador del flujo.
- El `PreRegistration_Service` será responsable de crear o reutilizar pre-registros, verificar identidad, solicitar OTP, confirmar OTP, crear la cuenta del tarjetahabiente y coordinar el envío de notificaciones.
- La generación y validación del OTP deberá realizarse mediante un componente especializado denominado `OTP_Service`, el cual podrá ser reutilizado para otros flujos de seguridad, como login MFA o cambio de PIN.
- El `OTP_Service` deberá generar códigos de seis dígitos, almacenar únicamente su hash y evitar persistir o registrar el OTP en claro.
- El OTP deberá tener una vigencia máxima de 5 minutos y un máximo de 3 intentos de validación.
- La validación de identidad deberá realizarse comparando el tipo de documento, número de documento y correo electrónico ingresados por el tarjetahabiente contra la información registrada para el cliente asociado al pre-registro.

- La verificación de identidad tendrá un máximo de 3 intentos. Al superar este límite, el pre-registro deberá pasar a estado BLOQUEADO, y el tarjetahabiente deberá contactar a la Entidad o canal operativo definido.
- La solicitud de reenvío de OTP deberá limitarse a un máximo de 3 solicitudes en 24 horas, aplicando bloqueo temporal de solicitudes cuando se supere este límite.
- Una vez validado correctamente el OTP, la solución deberá generar una sesión temporal de registro, denominada `session_registro`, con una vigencia máxima de 10 minutos, para permitir la creación de la contraseña.
- La contraseña asignada por el tarjetahabiente deberá cumplir una política mínima de seguridad: longitud mínima de 12 caracteres, al menos una mayúscula, una minúscula, un número y un carácter especial.
- La política de contraseña deberá validarse tanto en el lado cliente como en el lado servidor, garantizando que la validación del backend sea la regla definitiva.
- La contraseña no deberá almacenarse en la solución prepago. Su gestión, hash y almacenamiento deberán delegarse al SSO Keycloak, dentro del Realm CARDHOLDER.
- El usuario del tarjetahabiente en SSO deberá crearse utilizando como nombre de usuario el número de documento, asociado al `client_id` correspondiente.
- Al finalizar correctamente el flujo de creación de cuenta, la tabla `preregistration` deberá quedar en estado COMPLETADO y la tabla `app_user` deberá registrar un usuario activo asociado al cliente.
- El tarjetahabiente deberá poder acceder posteriormente al Portal Tarjetahabiente utilizando su número de documento y contraseña, mediante autenticación soportada por SSO Keycloak.
- El flujo de login operativo, restablecimiento de contraseña y cambio de contraseña se considera relacionado con el Portal Tarjetahabiente y podrá documentarse en la vista correspondiente del portal, aunque se referencia como parte del alcance funcional general.
- Todas las notificaciones del onboarding deberán enviarse mediante el servicio corporativo de correos definido, identificado como `B2B_Mail_Service` o servicio único de notificaciones transaccionales.
- Los correos enviados durante el onboarding deberán usar plantillas HTML controladas y no deberán incluir PAN, CVV2, contraseña, OTP en claro fuera del correo OTP autorizado, ni información sensible de tarjeta.
- El correo de OTP deberá incluir únicamente el código de verificación, su vigencia y advertencias de seguridad, evitando cualquier otro dato sensible.
- Las notificaciones contempladas para el flujo incluyen correo de pre-registro, reenvío de pre-registro, envío de OTP, bloqueo de OTP, bloqueo de solicitudes de OTP, confirmación de cuenta creada, notificación de login y correo para cuenta existente.
- La solución deberá registrar auditoría funcional, técnica y de seguridad de cada evento relevante del onboarding, incluyendo creación de pre-registro, verificación de identidad, emisión y validación de OTP, creación de usuario, errores y bloqueos.
- Los eventos sensibles deberán quedar registrados en `pci_event_log`, incluyendo fallas de identidad, bloqueos, validación OTP, creación de cuenta y errores en SSO.
- La solución deberá propagar un identificador de correlación, como `X-Correlation-Id`, desde el inicio del flujo hasta los componentes de auditoría y trazabilidad.
- Los errores expuestos por los servicios deberán manejarse de forma controlada, preferiblemente bajo un formato estándar como Problem Details, evitando exponer detalles técnicos internos al tarjetahabiente.
- La arquitectura deberá aplicar controles de seguridad en los endpoints del onboarding, incluyendo TLS 1.3, rate limiting, CAPTCHA en verificación de identidad, validación de esquema, manejo seguro de sesión, cookies seguras y headers de seguridad.
- El proceso de onboarding no deberá registrar en logs información sensible como OTP, contraseña, tokens completos, datos sensibles de tarjeta o respuestas técnicas no controladas.
- La información del proceso deberá persistirse en Oracle, incluyendo las tablas o estructuras asociadas a `preregistration`, `otp`, `app_user` y `client`.

- El estado del pre-registro deberá manejarse mediante una máquina de estados controlada, contemplando como mínimo los estados PENDIENTE, PENDING_NO_EMAIL, COMPLETADO, EXPIRADO y BLOQUEADO.
- El estado del OTP deberá manejarse mediante una máquina de estados controlada, contemplando como mínimo los estados ACTIVO, USADO, EXPIRADO y BLOQUEADO.
- El flujo deberá contemplar mecanismos de expiración automática o validación diferida para códigos de pre-registro y OTP vencidos.
- La arquitectura deberá considerar que el onboarding es un flujo cold-path, por lo cual no requiere los mismos niveles de latencia del motor transaccional de autorización, pero sí debe cumplir objetivos definidos de disponibilidad, respuesta y envío oportuno de correos.
- El servicio deberá contemplar capacidades de monitoreo sobre tasa de completitud, errores por fase, bloqueos, OTP expirados, fallas de correo, fallas de SSO y tiempos de respuesta.
- Cualquier definición pendiente asociada a UX de plantillas, mecanismo de visualización de contraseña, histórico de contraseñas, proveedor SMS, MFA en login o desbloqueo operativo deberá mantenerse como pendiente funcional o técnico hasta su validación con Producto, Arquitectura y Seguridad de la Información.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta para el proceso de **Onboarding de Tarjetahabiente**, entendido como el flujo de pre-registro, verificación de identidad, validación OTP, asignación de contraseña y creación de usuario en el Portal Tarjetahabiente para clientes con tarjeta prepago nominada.

- La arquitectura deberá limitar el flujo de onboarding a tarjetas nominadas. Las tarjetas innominadas no deberán disparar pre-registro automático, código UUID, OTP ni correo de activación dentro de este flujo.
- El proceso de onboarding deberá ejecutarse como una capacidad posterior a la creación de una tarjeta nominada, permitiendo que el tarjetahabiente active su cuenta en el Portal Tarjetahabiente mediante verificación de identidad, OTP y creación de contraseña.
- La solución deberá soportar tres disparadores del pre-registro: creación de tarjeta nominada, modificación del correo electrónico del tarjetahabiente y operación puntual desde el Portal Administrativo para reenvío manual del enlace. El requerimiento establece estos tres orígenes como disparadores formales del proceso.
- La generación del pre-registro deberá ser idempotente por `client_id` y no por `card_id`, de forma que un mismo tarjetahabiente con varias tarjetas no tenga múltiples pre-registros activos simultáneamente.
- Si existe un pre-registro vigente en estado PENDIENTE para el mismo cliente, la solución deberá reutilizar el código existente y reenviar el correo, en lugar de generar un nuevo código.
- El código de pre-registro deberá generarse como un UUID v4, asociado al cliente, con estado inicial PENDIENTE y vigencia máxima de 30 días.
- La URL de pre-registro deberá contener únicamente un código opaco. No deberá incluir datos personales, número de documento, correo electrónico, PAN, CVV2, identificadores internos de tarjeta ni información sensible del tarjetahabiente.
- El correo electrónico del tarjetahabiente deberá ser obligatorio para tarjetas nominadas, dado que es el canal requerido para enviar el enlace de pre-registro y el OTP.
- Los correos asociados al onboarding deberán enviarse únicamente mediante el servicio corporativo de notificaciones definido para la solución, evitando implementaciones de envío de correo directamente desde los componentes de front-end o desde servicios no gobernados.
- El servicio de correo deberá utilizar plantillas HTML controladas, trazabilidad de envío y remitente corporativo definido. El requerimiento establece el uso del `B2B_Mail_Service` como servicio único de correos transaccionales para el onboarding, con plantillas HTML y sin incluir PAN ni datos sensibles.
- El `PreRegistration_Portal` deberá actuar únicamente como capa de experiencia de usuario. No deberá acceder directamente a base de datos, SSO, OTP, servicios de correo ni repositorios internos.
- El front-end de pre-registro deberá consumir únicamente los servicios expuestos por `PreRegistration_API`, manteniendo separación entre interfaz, lógica de negocio, seguridad, persistencia e integración.
- El `PreRegistration_API` deberá validar esquema, formato de datos, cabeceras requeridas, correlación, rate limiting y controles de entrada antes de delegar la lógica de negocio al `PreRegistration_Service`.
- La lógica central del onboarding deberá residir en `PreRegistration_Service`, componente responsable de orquestar la creación o reutilización del pre-registro, verificación de identidad, solicitud y confirmación de OTP, creación de cuenta en SSO y coordinación de notificaciones.
- El `PreRegistration_Service` deberá ser el único componente autorizado para coordinar el flujo de negocio del onboarding y para invocar el `OTP_Service`, el `B2B_Mail_Service`, el SSO Keycloak y la persistencia en Oracle.

- El OTP_Service deberá mantenerse como componente especializado y reutilizable para generación y validación de OTP. Su responsabilidad debe limitarse a emitir, persistir y validar OTP, sin asumir responsabilidades de negocio del onboarding ni envío directo de correos.
- El OTP deberá generarse como código numérico de seis dígitos, con vigencia máxima de 5 minutos, máximo 3 intentos de validación y persistencia únicamente del hash del código.
- El OTP no deberá almacenarse en claro, no deberá escribirse en logs, no deberá exponerse en trazas, no deberá capturarse en consola del navegador y no deberá persistirse fuera de la estructura controlada definida para el servicio.
- La validación de identidad deberá ejecutarse comparando el código de pre-registro, tipo de documento, número de documento y correo electrónico contra la información del cliente asociado al pre-registro.
- El flujo de verificación de identidad deberá limitarse a máximo 3 intentos. Al superar el límite, el pre-registro deberá quedar en estado BLOQUEADO y el tarjetahabiente deberá contactar a la Entidad o canal operativo definido.
- El reenvío de OTP deberá estar controlado por límites de uso. El requerimiento define el endpoint POST /api/preregistro/resend-otp y establece que el reenvío cuenta contra el límite de solicitudes permitidas.
- Una vez validado correctamente el OTP, la solución deberá emitir una sesión temporal de registro, denominada session_registro, con vigencia máxima de 10 minutos, para permitir la creación de la cuenta.
- La session_registro deberá manejarse con controles de seguridad de sesión, incluyendo expiración, protección contra reutilización indebida y uso de cookies seguras cuando aplique.
- La asignación de contraseña deberá validarse tanto en el cliente como en el servidor. La validación del servidor deberá prevalecer sobre cualquier validación del front-end.
- La política de contraseña deberá exigir mínimo 12 caracteres, al menos una mayúscula, una minúscula, un número y un carácter especial. El requerimiento asocia esta política con controles de seguridad y delega el hash de contraseña a Keycloak.
- La contraseña no deberá persistirse en la base de datos de la solución prepago. La gestión de credenciales, almacenamiento de hash y autenticación posterior deberán delegarse al SSO Keycloak Realm CARDHOLDER.
- La creación de usuario en SSO deberá realizarse mediante una cuenta de servicio controlada, con permisos mínimos necesarios para crear usuarios en el Realm CARDHOLDER.
- El usuario creado en SSO deberá asociarse al client_id del tarjetahabiente y registrarse en la tabla app_user, manteniendo la relación entre cliente, usuario de aplicación y subject del SSO.
- Al completar exitosamente la creación de cuenta, el pre-registro deberá pasar a estado COMPLETADO, la cuenta del usuario deberá quedar activa y el tarjetahabiente deberá ser redirigido al Portal Tarjetahabiente.
- El Portal Tarjetahabiente y el Prepaid_Cardholder_API deberán ser considerados como destino posterior al onboarding. La autenticación operativa, restablecimiento de contraseña y cambio de contraseña deberán documentarse en la vista correspondiente del Portal Tarjetahabiente.
- La arquitectura deberá mantener máquinas de estado controladas para preregistration, otp y app_user, evitando actualizaciones directas o inconsistentes desde múltiples componentes.
- Los estados mínimos del pre-registro deberán contemplar PENDIENTE, PENDING_NO_EMAIL, COMPLETADO, EXPIRADO y BLOQUEADO.
- Los estados mínimos del OTP deberán contemplar ACTIVO, USADO, EXPIRADO y BLOQUEADO.
- La solución deberá contemplar mecanismos de expiración automática o validación diferida para pre-registros vencidos, OTP expirados y sesiones temporales vencidas.

- Todos los endpoints del onboarding deberán operar sobre TLS 1.3, aplicar validación de esquema, limitar solicitudes por IP, propagar X-Correlation-Id y responder errores de forma controlada. El requerimiento define TLS 1.3, rate limiting, CAPTCHA, correlación y errores bajo Problem Details para los endpoints.
- El formulario de verificación de identidad deberá incorporar mecanismos anti-bot, como CAPTCHA, y controles de limitación de tasa para reducir ataques automatizados.
- El portal de pre-registro deberá aplicar controles de seguridad web como CSP, SRI, HSTS, X-Frame-Options, X-Content-Type-Options y cookies Secure, HttpOnly y SameSite=Strict para sesiones temporales.
- La solución deberá evitar la exposición de información sensible en correos, logs, trazas, consola del navegador, respuestas de error, eventos de auditoría o herramientas de monitoreo.
- Las respuestas del API deberán enmascarar datos cuando aplique, por ejemplo el correo electrónico, y no deberán retornar OTP, contraseña, tokens completos, datos sensibles de tarjeta ni información interna de infraestructura.
- Todos los eventos relevantes del onboarding deberán registrarse en auditoría, incluyendo creación de pre-registro, verificación de identidad, intentos fallidos, emisión y validación de OTP, bloqueos, creación de usuario, errores de SSO y finalización del proceso.
- Los eventos sensibles deberán registrarse adicionalmente en pci_event_log, incluyendo identificación de usuario, tipo de evento, fecha y hora, éxito o fallo, origen, recurso afectado y componente ejecutor. El requerimiento define estos eventos para cumplimiento de auditoría PCI 10.2.
- Los payloads registrados en auditoría deberán estar enmascarados y no deberán incluir OTP, contraseña, tokens completos ni información sensible de tarjeta.
- El flujo deberá tener trazabilidad extremo a extremo mediante identificador de correlación propagado desde el portal hasta los servicios de negocio, correo, SSO, persistencia y auditoría.
- La arquitectura deberá permitir monitoreo funcional y técnico del proceso, incluyendo tasa de completitud, abandonos por fase, errores por tipo, bloqueos por intentos, OTP expirados, fallas de correo, fallas de SSO y tiempos de respuesta.
- La solución deberá cumplir los objetivos de operación definidos para el flujo, considerando que onboarding es un flujo cold-path y no hace parte del hot-path transaccional de autorización.
- La arquitectura deberá contemplar escalabilidad horizontal para los componentes API y de negocio, manteniendo consistencia fuerte sobre el estado de preregistration, otp y app_user.
- El diseño deberá evitar caché de estado para el código de pre-registro y para el estado del proceso cuando la consistencia fuerte sea requerida.
- Los errores del proceso deberán clasificarse de forma funcional y técnica, diferenciando link inválido, link expirado, link usado, datos no coincidentes, OTP inválido, OTP expirado, OTP bloqueado, política de contraseña incumplida, correo duplicado y error SSO.
- Los mensajes al tarjetahabiente deberán ser claros, controlados y orientados a la acción, evitando exponer detalles técnicos internos.
- La solución deberá contemplar pruebas de seguridad obligatorias sobre los endpoints de onboarding, incluyendo pruebas de fuerza bruta sobre OTP y verificación de identidad, así como pruebas SAST y DAST sobre los componentes expuestos.
- Cualquier definición pendiente asociada a plantillas UX, visualización de contraseña, histórico de contraseñas, proveedor SMS, reglas de MFA, desbloqueo operativo o reenvío automático de correos deberá quedar identificada como pendiente hasta su validación con Producto, Arquitectura y Seguridad de la Información.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta para el proceso de **Onboarding de Tarjetahabiente**, considerando el flujo de pre-registro, verificación de identidad, validación OTP, asignación de contraseña y creación de usuario en el Portal Tarjetahabiente para clientes con tarjeta prepago nominada. El requerimiento define que este flujo aplica al pre-registro y activación de cuenta del tarjetahabiente, excluyendo tarjetas innominadas y flujos transaccionales como autorización, activación de PIN y cambio de PIN.

- El flujo de onboarding deberá aplicar únicamente para tarjetas nominadas. Las tarjetas innominadas quedan excluidas de este proceso y deberán gestionarse mediante el flujo definido para activación de tarjetas innominadas.
- El proceso no deberá generar pre-registro, UUID, OTP ni correo automático para tarjetas innominadas.
- El onboarding masivo o por archivo no hace parte del alcance funcional directo del portal de pre-registro. El pre-registro se dispara como consecuencia de la creación de una tarjeta nominada, de la modificación de correo electrónico del tarjetahabiente o de una operación puntual desde el Portal Administrativo.
- Los flujos transaccionales de autorización, activación de PIN, cambio de PIN y visualización de datos sensibles de tarjeta no hacen parte de este concepto. Estos deberán documentarse y validarse en sus respectivos diagramas y conceptos de arquitectura.
- El proceso de pre-registro deberá ser idempotente por `client_id`. No se deberán generar múltiples pre-registros activos para un mismo cliente cuando ya exista un registro en estado PENDIENTE y con vigencia activa.
- El código de pre-registro deberá tener una vigencia máxima de 30 días. Una vez expirado, no deberá permitir continuar con la activación de cuenta.
- La URL de pre-registro no deberá contener información sensible o identificadores directos del tarjetahabiente. Solo deberá transportar un código opaco, tipo UUID, que permita resolver internamente el pre-registro.
- El correo electrónico del tarjetahabiente es obligatorio para ejecutar el onboarding. Si la tarjeta nominada no cuenta con correo válido, el proceso deberá quedar en un estado controlado, como `PENDING_NO_EMAIL`, o en el estado operativo que se defina para gestión manual.
- El enlace de pre-registro deberá enviarse únicamente al correo registrado para el tarjetahabiente. No se deberán habilitar envíos a correos alternos sin que previamente exista una modificación formal de datos por el proceso definido.
- El `PreRegistration_Portal` no deberá acceder directamente a la base de datos, SSO, servicios de correo ni servicios de OTP. Toda interacción deberá realizarse mediante `PreRegistration_API`.
- El `PreRegistration_API` no deberá implementar lógica de negocio crítica del onboarding. Su responsabilidad deberá limitarse a exposición de endpoints, validación de entrada, controles técnicos y delegación hacia `PreRegistration_Service`.
- El `PreRegistration_Service` deberá ser el componente responsable de orquestar el flujo de negocio. No se deberán crear rutas alternas que permitan invocar directamente el `OTP_Service`, el SSO o el servicio de correo desde el front-end o desde componentes no autorizados.
- La validación de identidad deberá exigir coincidencia de tipo de documento, número de documento y correo electrónico contra la información registrada del cliente asociado al pre-registro.
- La verificación de identidad tendrá un máximo de 3 intentos. Al superar este número, el pre-registro deberá quedar bloqueado y el tarjetahabiente deberá contactar a la Entidad o canal operativo definido.

- El OTP deberá tener una vigencia máxima de 5 minutos. Un OTP expirado no deberá ser aceptado, aunque el código ingresado sea correcto.
- El OTP deberá tener un máximo de 3 intentos de validación. Al superar el límite, el OTP deberá quedar en estado BLOQUEADO.
- El OTP no deberá almacenarse en claro. Solo deberá persistirse su hash, según el mecanismo definido para el OTP_Service.
- El OTP no deberá registrarse en logs, trazas, eventos, consola del navegador, herramientas de monitoreo ni auditoría en texto claro.
- El reenvío de OTP deberá estar limitado. No se deberán permitir más de 3 solicitudes de OTP en 24 horas para el mismo proceso, cliente o criterio equivalente definido por arquitectura.
- La session_registro emitida después de validar correctamente el OTP deberá tener una vigencia máxima de 10 minutos. Vencido este tiempo, la creación de cuenta deberá ser rechazada y el tarjetahabiente deberá reiniciar desde la etapa correspondiente.
- La session_registro no deberá reutilizarse para múltiples operaciones ni mantenerse activa después de completar la creación de cuenta.
- La contraseña asignada por el tarjetahabiente deberá cumplir la política mínima definida: 12 caracteres, al menos una mayúscula, una minúscula, un número y un carácter especial.
- La validación de contraseña en el front-end no será suficiente. La política deberá validarse obligatoriamente en backend antes de crear el usuario en SSO.
- La contraseña no deberá almacenarse en la base de datos de la solución prepago. La gestión de credenciales, hash y autenticación deberá delegarse a SSO Keycloak Realm CARDHOLDER.
- La contraseña no deberá registrarse en logs, trazas, eventos de auditoría, mensajes de error, consola del navegador ni herramientas de monitoreo.
- La creación de usuario en Keycloak deberá realizarse mediante una cuenta de servicio controlada, con permisos mínimos requeridos para operar sobre el Realm CARDHOLDER.
- No se deberá crear un usuario en SSO si previamente no se ha validado correctamente la identidad, el OTP y la política de contraseña.
- No se deberá marcar el pre-registro como COMPLETADO si la creación de usuario en SSO o la inserción en app_user no finaliza correctamente.
- La relación entre client_id, app_user y sso_subject deberá mantenerse única y consistente. No se deberán permitir múltiples usuarios activos para un mismo client_id.
- El username del tarjetahabiente deberá corresponder al número de documento, salvo que Producto, Arquitectura y Seguridad definan formalmente un criterio diferente.
- El flujo no deberá exponer PAN, CVV2, fecha de expiración, PIN, contraseña, OTP o tokens completos en correos, respuestas API, logs, trazas o mensajes al usuario.
- Los correos del onboarding deberán enviarse únicamente mediante el servicio corporativo definido, como B2B_Mail_Service o servicio equivalente aprobado. No se deberán implementar envíos SMTP directos desde otros componentes.
- Las plantillas de correo deberán estar controladas y aprobadas. No deberán incluir información sensible de tarjeta ni credenciales.
- El correo de OTP solo deberá incluir el código de verificación, su vigencia y advertencias de seguridad. No deberá incluir datos sensibles de tarjeta ni enlaces que permitan evadir etapas del flujo.
- Los endpoints del onboarding deberán operar obligatoriamente bajo TLS 1.3 o el estándar de seguridad definido por Credibanco.
- El endpoint de verificación de identidad deberá contar con mecanismos anti-bot, como CAPTCHA, y controles de rate limiting.
- Todos los endpoints deberán aplicar controles de rate limiting. No se deberán permitir intentos ilimitados desde una misma IP, sesión, cliente o identificador funcional.
- Los errores expuestos al tarjetahabiente deberán ser controlados y no deberán revelar detalles técnicos internos, estructura de base de datos, comportamiento de Keycloak, stack traces, nombres de tablas o información de infraestructura.

- Las respuestas de error deberán seguir un formato controlado, preferiblemente Problem Details o el estándar definido por Credibanco, manteniendo mensajes funcionales claros y seguros.
- La arquitectura deberá propagar un identificador de correlación, como X-Correlation-Id, desde el inicio del flujo hasta auditoría, notificaciones, persistencia y llamadas a SSO.
- Todos los eventos relevantes deberán quedar registrados en audit_log, con payloads enmascarados y sin información sensible.
- Los eventos sensibles del onboarding deberán registrarse en pci_event_log, especialmente fallas de verificación de identidad, bloqueos, emisión y validación de OTP, creación de cuenta, incumplimiento de política de contraseña y errores en SSO.
- La auditoría no deberá almacenar OTP, contraseña, tokens completos ni datos sensibles de tarjeta.
- Los estados de preregistration, otp y app_user deberán modificarse únicamente mediante los servicios autorizados. No se deberán permitir actualizaciones directas por componentes externos o procesos no gobernados.
- El estado BLOQUEADO deberá requerir un procedimiento operativo definido para desbloqueo o reinicio del proceso. Mientras dicho procedimiento no esté formalizado, no se deberá asumir desbloqueo automático, salvo para los casos expresamente definidos, como bloqueos temporales de OTP o login.
- Los pre-registros vencidos deberán pasar a estado EXPIRADO mediante job, validación diferida o mecanismo equivalente. No deberán permanecer indefinidamente en estado PENDIENTE.
- El flujo deberá mantener consistencia fuerte sobre los estados de preregistration, otp y app_user. No se deberá usar caché para decidir estados críticos del proceso si esto puede generar inconsistencias.
- La solución deberá operar bajo los estándares tecnológicos definidos por Credibanco para despliegue, gestión de secretos, observabilidad, auditoría, seguridad web, monitoreo y gobierno de componentes.
- La disponibilidad del SMTP corporativo, SSO Keycloak y Oracle será una dependencia directa del flujo. Si alguno de estos componentes presenta falla, el proceso deberá responder de forma controlada y registrar el evento para gestión operativa.
- El proceso deberá considerar que el onboarding es un flujo cold-path y no un flujo transaccional de autorización. Sin embargo, deberá cumplir los SLA definidos para latencia, disponibilidad y envío oportuno de correos.
- No se deberán activar funcionalidades pendientes sin validación formal, incluyendo proveedor SMS, MFA en login, histórico de contraseñas, desbloqueo operativo, federación con entidades emisoras o reglas adicionales de autenticación.
- Las plantillas UX, mensajes al usuario, visualización de contraseña, textos de error, confirmación de cuenta creada y comunicaciones de bloqueo deberán ser validadas con UX, Producto y Seguridad de la Información antes de salida a producción.
- Cualquier modificación posterior sobre TTL, número de intentos, política de contraseña, estructura de endpoints, comportamiento de OTP, creación de usuario en SSO, plantillas de correo o reglas de auditoría deberá pasar por control de cambios funcional, técnico y arquitectónico.

Descripción de componentes

Identificador	Componente	Descripción
OBT-001	Tarjetahabiente	Actor final del proceso de onboarding. Recibe el correo de pre-registro, accede al enlace único, valida su identidad, ingresa el OTP, asigna contraseña y posteriormente accede al Portal Tarjetahabiente.
OBT-002	Prepaid_Card_Creation_Orchestrator	Componente externo al flujo de onboarding que actúa como disparador cuando se crea una tarjeta prepago nominada. Si el tarjetahabiente no tiene usuario registrado, invoca el proceso de pre-registro.
OBT-003	Prepaid_Non_Monetary_Novelty_Processor	Componente externo al flujo de onboarding que actúa como disparador cuando se modifica el correo electrónico del tarjetahabiente y este aún no tiene usuario registrado en el portal.
OBT-004	Prepaid_Admin_API	Componente administrativo que permite ejecutar una operación puntual de reenvío manual del enlace de pre-registro cuando el tarjetahabiente reporta que no recibió el correo.
OBT-005	PreRegistration_Portal	Aplicación web pública utilizada por el tarjetahabiente para completar el flujo de onboarding. Presenta las pantallas de verificación de identidad, validación OTP, asignación de contraseña y confirmación de cuenta creada. Debe aplicar controles de seguridad web como CAPTCHA, CSP, SRI y rate limiting de cliente.
OBT-006	PreRegistration_API	Capa de servicios expuesta al PreRegistration_Portal. Publica los endpoints requeridos para el proceso, como verificación de identidad, validación de OTP, reenvío de OTP y creación de cuenta. Debe validar esquema, entrada, correlación, seguridad de transporte y delegar la lógica de negocio al PreRegistration_Service.
OBT-007	PreRegistration_Service	Componente central de negocio y orquestador del onboarding. Administra la creación o reutilización del pre-registro, verificación de identidad, solicitud y confirmación de OTP, emisión de session_registro, creación de cuenta en SSO, actualización de estados, persistencia, auditoría y coordinación de notificaciones.
OBT-008	OTP_Service	Servicio especializado y reutilizable para generación y validación de OTP. Genera códigos de seis dígitos, almacena únicamente el hash del OTP, controla expiración, intentos máximos y estados del código. Retorna el OTP en memoria al caller y no envía correos directamente.
OBT-009	B2B_Mail_Service	Servicio corporativo único de correos transaccionales utilizado para enviar notificaciones del onboarding, incluyendo enlace de pre-registro, OTP, bloqueos, confirmación de cuenta creada y comunicaciones relacionadas. Debe usar plantillas HTML, registrar auditoría de envío y no incluir PAN, CVV2, contraseñas ni información sensible de tarjeta.

OBT-010	SMTP Server	Infraestructura de correo corporativo usada por B2B_Mail_Service para la entrega de correos al tarjetahabiente. Opera como canal saliente y debe garantizar comunicación segura para el envío de notificaciones.
OBT-011	SSO Keycloak — Realm CARDHOLDER	Solución de identidad donde se crea y administra el usuario del tarjetahabiente. Gestiona credenciales, hash de contraseña, roles, estado del usuario y emisión de tokens JWT para acceso posterior al Portal Tarjetahabiente.
OBT-012	Oracle Primary	Base de datos transaccional que almacena la información del proceso de onboarding, incluyendo las tablas preregistration, otp, app_user y client. Permite mantener la trazabilidad del pre-registro, OTP, usuario de aplicación y cliente asociado.
OBT-013	Audit_Service	Componente transversal encargado de registrar eventos funcionales, técnicos y de seguridad del onboarding. Registra eventos en audit_log y pci_event_log, incluyendo creación de pre-registro, verificación de identidad, emisión y validación de OTP, bloqueos, creación de cuenta y errores de SSO.
OBT-014	Portal Tarjetahabiente	Aplicación destino posterior al onboarding. Una vez creada la cuenta, el tarjetahabiente es redirigido al portal para autenticarse con su número de documento y contraseña. El detalle de login, restablecimiento y cambio de contraseña pertenece al flujo del Portal Tarjetahabiente.
OBT-015	Prepaid_Cardholder_API	API del Portal Tarjetahabiente encargada de atender las consultas y operaciones del tarjetahabiente autenticado. Valida el JWT emitido por Keycloak y permite acceder a las capacidades del portal una vez finalizado el onboarding.
OBT-016	Authorization Gateway / API Gateway	Componente de entrada para las APIs expuestas, encargado de aplicar controles transversales como enrutamiento, validación de seguridad, propagación de X-Correlation-Id, control de tráfico, rate limiting y manejo de errores controlados.
OBT-017	Preregistration Table	Estructura lógica en Oracle que almacena el código UUID, client_id, correo, estado del pre-registro, fecha de expiración, intentos y fecha de completitud. Sus estados principales son PENDIENTE, PENDING_NO_EMAIL, COMPLETADO, EXPIRADO y BLOQUEADO.
OBT-018	OTP Table	Estructura lógica en Oracle que almacena el hash del OTP, propósito, vigencia, número de intentos, máximo de intentos, estado y asociación con el cliente. Sus estados principales son ACTIVO, USADO, EXPIRADO y BLOQUEADO.
OBT-019	App_User Table	Estructura lógica en Oracle que almacena la relación entre el client_id, el usuario de aplicación, el username, el sso_subject de Keycloak y el estado del usuario dentro de la solución prepago.
OBT-020	Client Table	Estructura lógica en Oracle que almacena la información base del tarjetahabiente, utilizada para validar identidad, comparar tipo y número de documento, validar correo electrónico y construir atributos del usuario en SSO.

OBT-021	Security Controls	Conjunto de controles transversales aplicables al flujo de onboarding, incluyendo TLS 1.3, CAPTCHA, rate limiting, CSP, SRI, HSTS, cookies seguras, X-Frame-Options, validación de esquema, hash de OTP, hash de contraseña delegado a Keycloak y manejo seguro de errores.
OBT-022	Observability / Monitoring	Capacidad de monitoreo técnico y funcional del onboarding. Permite medir pre-registros creados, completados, expirados y bloqueados; OTP emitidos, validados y expirados; fallas de correo; errores SSO; tiempos de respuesta y tasa de abandono por fase.
OBT-023	Notification Templates	Conjunto de plantillas HTML utilizadas por B2B_Mail_Service para enviar comunicaciones al tarjetahabiente, tales como correo de pre-registro, reenvío de enlace, OTP, bloqueo de OTP, bloqueo de solicitudes, confirmación de cuenta creada y cuenta existente.
OBT-024	PCI Event Log	Repositorio lógico de eventos sensibles relacionados con seguridad y cumplimiento. Registra eventos como creación de pre-registro, verificación de identidad, fallas, bloqueos, emisión/validación de OTP, creación de cuenta, violación de política de contraseña y errores en SSO.
OBT-025	Audit Log	Repositorio lógico de auditoría funcional y técnica. Almacena operación ejecutada, componente, identificador de correlación, payload enmascarado, resultado, tiempo de respuesta, usuario o cliente asociado y estado final de la operación.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

El proceso de Onboarding Tarjetahabiente permite que un tarjetahabiente con tarjeta prepago nominada active su cuenta en el Portal Tarjetahabiente, mediante un flujo controlado de pre-registro, verificación de identidad, validación OTP, asignación de contraseña y creación de usuario en el SSO corporativo. Este flujo aplica únicamente para tarjetas nominadas y tiene como resultado esperado la creación de un usuario activo en SSO Keycloak Realm CARDHOLDER, el registro correspondiente en app_user, el pre-registro en estado COMPLETADO y la habilitación del acceso al portal con número de documento y contraseña.

La arquitectura propuesta centraliza la lógica del proceso en el componente PreRegistration_Service, el cual coordina la creación o reutilización del pre-registro, la validación de identidad, la solicitud y confirmación del OTP, la creación del usuario en SSO, la actualización de estados, la persistencia, la auditoría y el envío de notificaciones.

1. Disparo del proceso de onboarding

El proceso inicia cuando se presenta alguno de los disparadores definidos para el onboarding del tarjetahabiente:

- Creación de una tarjeta prepago nominada.
- Modificación del correo electrónico del tarjetahabiente.
- Operación puntual desde el Portal Administrativo para reenvío manual del enlace de pre-registro.

En el primer escenario, el componente `Prepaid_Card_Creation_Orchestrator` invoca el proceso después de la creación de una tarjeta nominada, siempre que el tarjetahabiente no tenga usuario registrado previamente en `app_user`.

En el segundo escenario, el componente `Prepaid_Non_Monetary_Novelty_Processor` invoca el proceso cuando se actualiza el correo electrónico del tarjetahabiente y este aún no tiene usuario activo en el portal.

En el tercer escenario, el componente `Prepaid_Admin_API` permite ejecutar una operación manual de reenvío del enlace de pre-registro cuando el tarjetahabiente informa que no recibió el correo o requiere una nueva notificación operativa.

El requerimiento define estos tres disparadores y establece que el `PreRegistration_Service` debe decidir si genera un nuevo código o reutiliza un pre-registro pendiente vigente.

2. Validación de existencia de usuario

Una vez recibido el disparador, el `PreRegistration_Service` valida si el tarjetahabiente ya cuenta con un usuario registrado en la solución.

Para ello, consulta la tabla `app_user` utilizando el `client_id` asociado al tarjetahabiente. Si el usuario ya existe y se encuentra activo, no se debe generar un nuevo pre-registro. En este caso, la solución podrá enviar una comunicación de acceso directo al Portal Tarjetahabiente, de acuerdo con la plantilla definida para usuarios existentes.

Si el usuario no existe, el proceso continúa con la creación o reutilización del pre-registro.

Esta regla permite evitar duplicidad de usuarios y asegura que el onboarding sea gestionado por cliente y no por tarjeta.

3. Creación o reutilización del pre-registro

El `PreRegistration_Service` valida si ya existe un pre-registro vigente para el mismo `client_id`.

Si existe un registro en estado PENDIENTE y con fecha de expiración mayor a la fecha actual, el servicio reutiliza el código existente y procede a reenviar el correo de pre-registro.

Si no existe un pre-registro vigente, el servicio genera un nuevo código único tipo UUID v4, lo asocia al `client_id`, registra el correo electrónico del tarjetahabiente y persiste el pre-registro en la tabla `preregistration` con:

- Estado inicial PENDIENTE.
- Vigencia de 30 días.
- Intentos iniciales en cero.
- Fecha de creación.
- Usuario o componente creador.

El proceso debe ser idempotente por `client_id`, no por `card_id`, de manera que si un mismo tarjetahabiente recibe varias tarjetas, se mantenga un único pre-registro vigente asociado al cliente.

4. Construcción y envío del enlace de pre-registro

Una vez creado o reutilizado el pre-registro, el `PreRegistration_Service` construye la URL de activación utilizando el código UUID generado.

La URL debe ser opaca y no debe exponer datos personales, número de documento, correo electrónico, información de tarjeta, PAN, CVV2, PIN ni identificadores internos sensibles. El enlace se envía al correo electrónico registrado del tarjetahabiente.

El envío de la notificación se realiza a través del `B2B_Mail_Service`, que aplica la plantilla HTML correspondiente y utiliza el SMTP Server corporativo para la entrega del correo.

El correo de pre-registro debe incluir:

- Saludo e instrucciones generales.
- Enlace de activación.
- Vigencia del enlace.
- Advertencias de seguridad.
- Información de contacto o soporte según defina negocio.

No debe incluir información sensible de tarjeta, credenciales, contraseña, PAN, CVV2, PIN ni OTP.

El envío del correo debe quedar registrado en auditoría para trazabilidad operativa y funcional.

5. Acceso del tarjetahabiente al portal de pre-registro

El tarjetahabiente recibe el correo y accede al enlace de pre-registro.

El enlace abre el PreRegistration_Portal, aplicación web pública que presenta la interfaz de activación de cuenta. El portal valida que el código venga en la URL y presenta al tarjetahabiente el formulario de verificación de identidad.

El PreRegistration_Portal actúa únicamente como capa de experiencia de usuario. No accede directamente a la base de datos, SSO, OTP o servicios de correo. Todas sus operaciones se realizan mediante consumo de los endpoints expuestos por PreRegistration_API.

6. Verificación de identidad

En esta fase, el tarjetahabiente debe ingresar la información requerida para validar que corresponde al titular asociado al pre-registro.

Los datos solicitados son:

- Tipo de documento.
- Número de documento.
- Correo electrónico registrado.
- Los tipos de documento soportados son:
- Cédula de ciudadanía.
- Cédula de extranjería.
- Tarjeta de identidad.
- Permiso de protección temporal.

El portal invoca el endpoint de verificación del PreRegistration_API, enviando el código de pre-registro y los datos ingresados por el tarjetahabiente.

El PreRegistration_API valida estructura de la solicitud, controles técnicos y delega la lógica de negocio al PreRegistration_Service.

El PreRegistration_Service valida:

- Que el código exista.
- Que el código no esté expirado.
- Que el pre-registro esté en estado **PENDIENTE**.
- Que el tipo y número de documento coincidan con el cliente asociado al pre-registro.
- Que el correo electrónico coincida con el correo registrado.
- Que no se hayan superado los intentos permitidos.

Si la validación es exitosa, el proceso avanza hacia la generación de OTP. Si la validación falla, se incrementa el contador de intentos. Al superar tres intentos, el pre-registro pasa a estado BLOQUEADO y el tarjetahabiente debe contactar a la Entidad o canal operativo definido.

El requerimiento establece que la verificación de identidad debe validar tipo y número de documento y correo, con máximo tres intentos antes de bloquear el proceso.

7. Generación y envío de OTP

Cuando la verificación de identidad es exitosa, el PreRegistration_Service solicita al OTP_Service la generación de un código OTP con propósito PRE_REGISTRO.

El OTP_Service genera un código numérico de seis dígitos y calcula su hash. El código en claro no se almacena en base de datos ni se registra en logs. Solo se persiste el hash del OTP en la tabla otp, junto con:

- client_id.
- Propósito del OTP.
- Estado **ACTIVO**.
- Vigencia de **5 minutos**.
- Intentos iniciales en cero.
- Máximo de tres intentos.
- Fecha de creación.

El OTP es retornado en memoria al PreRegistration_Service, que coordina el envío del código al correo registrado mediante B2B_Mail_Service.

El OTP_Service no envía correos directamente. Su responsabilidad se limita a generar, persistir y validar OTP. El envío de comunicaciones permanece centralizado en el servicio corporativo de notificaciones.

8. Validación de OTP

El tarjetahabiente recibe el OTP en su correo electrónico y lo ingresa en el PreRegistration_Portal.

El portal invoca el endpoint de validación de OTP del PreRegistration_API, enviando el código de pre-registro y el OTP ingresado.

El PreRegistration_API delega la validación al PreRegistration_Service, que resuelve el OTP activo asociado al client_id del pre-registro y solicita al OTP_Service ejecutar la validación.

El OTP_Service calcula el hash del OTP ingresado y lo compara contra el hash almacenado. También valida que:

- El OTP esté en estado **ACTIVO**.
- No haya expirado.
- No haya superado el máximo de intentos.

Si el OTP es correcto, el servicio lo marca como USADO y retorna confirmación al PreRegistration_Service.

Si el OTP es incorrecto, se incrementa el contador de intentos. Si se superan los tres intentos, el OTP se marca como BLOQUEADO. Si el OTP está vencido, se marca como EXPIRADO o se rechaza por expiración según el mecanismo implementado.

Cuando el OTP se valida correctamente, el PreRegistration_Service emite una sesión temporal denominada session_registro, con vigencia máxima de 10 minutos, que habilita la fase de creación de contraseña.

9. Reenvío de OTP

El proceso contempla la posibilidad de reenviar el OTP mediante el endpoint:

POST /api/preregistro/resent-otp

Este reenvío debe estar controlado por reglas de límite de solicitudes. El requerimiento establece un máximo de tres solicitudes de OTP en una ventana de 24 horas. Al superar este límite, se debe bloquear temporalmente la solicitud de nuevos OTP y notificar al tarjetahabiente mediante el mensaje correspondiente.

El reenvío de OTP debe generar un nuevo registro de OTP o invalidar el anterior según la regla técnica definida, manteniendo trazabilidad y auditoría de cada solicitud.

10. Asignación de contraseña

Con la session_registro activa, el PreRegistration_Portal presenta al tarjetahabiente el formulario de creación de contraseña.

El tarjetahabiente debe ingresar y confirmar su nueva contraseña. La política mínima exige:

Mínimo 12 caracteres.

Al menos una letra mayúscula.

Al menos una letra minúscula.

Al menos un número.

Al menos un carácter especial.

La validación debe realizarse en el front-end para mejorar la experiencia de usuario, pero la validación definitiva debe ejecutarse en el backend.

El PreRegistration_API recibe la solicitud de creación de cuenta y la delega al PreRegistration_Service, que valida:

- Que el código de pre-registro sea válido.
- Que la session_registro exista y no haya expirado.
- Que la contraseña cumpla la política definida.
- Que el pre-registro siga en estado válido para completar la cuenta.
- Que no exista un usuario activo previamente asociado al mismo client_id.

La contraseña no debe almacenarse ni registrarse en la solución prepago. Su gestión se delega a **SSO Keycloak**.

11. Creación de usuario en SSO Keycloak

Una vez validada la contraseña, el PreRegistration_Service invoca a SSO Keycloak Realm CARDHOLDER para crear el usuario del tarjetahabiente.

La creación del usuario debe incluir:

- username igual al número de documento del tarjetahabiente.
- Correo electrónico registrado.
- Nombre y apellido desde la información del cliente.
- Atributos como client_id, entity_id y teléfono, cuando apliquen.
- Rol CARDHOLDER.
- Usuario habilitado.
- Contraseña gestionada por Keycloak.

Keycloak se encarga del hash y gestión de la contraseña. La solución prepago no debe almacenar credenciales ni hashes de contraseña.

Si Keycloak responde exitosamente, el proceso continúa con la creación del usuario de aplicación. Si Keycloak retorna error, el flujo debe responder de forma controlada, registrar auditoría, evitar marcar el pre-registro como completado y dejar el evento disponible para revisión operativa.

12. Registro del usuario en la solución prepago

Después de la creación exitosa en SSO, el PreRegistration_Service registra la relación del usuario en la tabla app_user.

Este registro debe incluir:

- client_id.
- username.
- sso_subject retornado por Keycloak.
- Estado ACTIVO.
- Fecha de creación.
- Usuario o componente creador.

Posteriormente, el servicio actualiza el registro de preregistration a estado COMPLETADO, registrando la fecha de finalización del proceso.

Este paso asegura que la solución prepago tenga una relación interna entre el cliente y el usuario creado en el SSO.

13. Confirmación al tarjetahabiente y redirección al portal

Una vez finalizado exitosamente el proceso, el PreRegistration_Service responde al PreRegistration_API, y este retorna la confirmación al PreRegistration_Portal.

El portal muestra un mensaje de cuenta creada exitosamente y presenta la opción de ir al Portal Tarjetahabiente.

El tarjetahabiente será redirigido al portal para realizar su autenticación con número de documento y contraseña. A partir de este punto, el flujo operativo de login y consumo de funcionalidades del portal se gestiona mediante el Portal Tarjetahabiente, Prepaid_Cardholder_API y SSO Keycloak.

14. Auditoría y trazabilidad del proceso

Durante todo el proceso, los componentes deben registrar auditoría funcional, técnica y de seguridad.

El Audit_Service debe registrar eventos como:

- Creación o reutilización de pre-registro.
- Envío de correo de pre-registro.
- Acceso al enlace.
- Verificación de identidad exitosa o fallida.
- Bloqueo por intentos de identidad.
- Emisión de OTP.
- Reenvío de OTP.
- Validación de OTP exitosa o fallida.
- Bloqueo o expiración de OTP.
- Creación de session_registro.
- Intento de creación de cuenta.
- Incumplimiento de política de contraseña.
- Creación de usuario en SSO.
- Error en Keycloak.
- Registro en app_user.
- Cambio de estado del pre-registro.
- Finalización del onboarding.

Los eventos sensibles deben registrarse también en pci_event_log, incluyendo identificación del usuario o cliente, tipo de evento, fecha y hora, resultado, origen, recurso afectado y componente ejecutor.

La auditoría no debe almacenar OTP, contraseña, tokens completos, PAN, CVV2, PIN ni información sensible de tarjeta.

15. Manejo de errores y excepciones

La solución debe manejar errores de forma controlada, diferenciando errores funcionales, técnicos y de seguridad.

Los principales escenarios son:

- Código de pre-registro inexistente o malformado.
- Código expirado.
- Código ya utilizado.
- Pre-registro bloqueado.
- Datos de identidad no coincidentes.
- Límite de intentos de identidad superado.
- OTP inválido.
- OTP expirado.
- OTP bloqueado.
- Límite de reenvíos de OTP superado.
- session_registro vencida.
- Contraseña que no cumple política.
- Correo electrónico duplicado.
- Error en Keycloak.
- Error en persistencia.
- Error en envío de correo.

- Error técnico no controlado.

Para cada caso, la solución deberá retornar mensajes claros al tarjetahabiente, sin exponer detalles técnicos internos. Los errores deben registrarse en auditoría con el identificador de correlación correspondiente.

16. Seguridad del flujo

El proceso debe operar bajo controles de seguridad en todas sus fases. Como mínimo, se deben aplicar:

- TLS 1.3 en endpoints y comunicaciones relevantes.
- CAPTCHA en verificación de identidad.
- Rate limiting por endpoint.
- Validación de esquema.
- Headers de seguridad web.
- Cookies seguras para sesión temporal.
- Hash de OTP.
- Hash de contraseña delegado a Keycloak.
- Enmascaramiento de datos en respuestas.
- No registro de OTP ni contraseña en logs.
- No exposición de información sensible en correos.
- Manejo controlado de errores.
- Propagación de X-Correlation-Id.
- Auditoría en audit_log y pci_event_log.

Estos controles buscan reducir riesgos de suplantación, fuerza bruta, reutilización indebida de enlaces, exposición de credenciales, abuso de OTP y pérdida de trazabilidad.

17. Cierre del proceso

El proceso de onboarding finaliza cuando ocurre una de las siguientes condiciones:

- El tarjetahabiente completa exitosamente la verificación de identidad, valida el OTP, asigna contraseña, se crea el usuario en SSO, se registra en app_user, el pre-registro queda en estado COMPLETADO y se redirige al Portal Tarjetahabiente.
- El proceso queda bloqueado por superar los intentos permitidos de verificación de identidad, validación de OTP o solicitudes de reenvío.
- El proceso expira por vencimiento del código de pre-registro, OTP o session_registro.
- El proceso queda pendiente de gestión operativa por falta de correo, error en envío de notificación, error en SSO, inconsistencia de datos o condición que requiera revisión manual.

Con este proceso, Credibanco garantiza que la activación de cuenta del tarjetahabiente se realice de forma segura, controlada, auditable y consistente con el ciclo de vida de tarjetas prepago nominadas, manteniendo separación entre experiencia de usuario, servicios de negocio, identidad, OTP, notificaciones, persistencia y auditoría.

Aplicaciones y/o soluciones afectadas

<Listar aplicaciones y/o soluciones afectadas con la arquitectura propuesta.>

<Autores: Arquitecto >

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.